

DAMM v2

Release 0.2.4

Smart Contract Security Assessment

September 2026

Prepared for:

Meteora

Prepared by:

Offside Labs

Sirius Xie





Contents

1	About Offside Labs	2
2	Executive Summary	3
3	Summary of Findings	5
4	Key Findings and Recommendations	6
4.1	Token-2022 Native Mint Check Can Be Skipped	6
4.2	Informational and Undetermined Issues	7
5	Disclaimer	8



1 About Offside Labs

Offside Labs is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **\$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **\$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.



<https://offside.io/>



<https://github.com/offsidelabs>



https://twitter.com/offside_labs



2 Executive Summary

Introduction

Offside Labs completed a security audit of DAMM v2 smart contracts, starting on September 2nd, 2026, and concluding on September 7th, 2026.

Project Overview

Meteora DAMM v2 Release 0.2.4 introduces a configurable mint validation bypass for private static and dynamic pool configurations. Authorized configuration operators can delegate pool creation without the standard supported mint and token approval checks, while public configurations retain existing validation. The release also consolidates permission bitmask bounds checking and extends configuration creation parameters and events to expose the new permission setting.

Audit Scope

The assessment scope contains mainly the smart contracts of the cp-amm program for the DAMM v2 project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- DAMM v2
 - Codebase: <https://github.com/MeteoraAg/damm-v2>
 - Release 0.2.4: [PR-225](#)
 - Commit Hash: 90684ba655df9ed35fda442ee4213fd1145670e5

The issues described in this report have been resolved by the following commit:

- DAMM v2
 - Codebase: <https://github.com/MeteoraAg/damm-v2>
 - Commit Hash: 85bd0b4d049405d8db460fa58d6b7753e1d0785b

We listed the files we have audited below:

- DAMM v2 Release 0.2.4
 - programs/cp-amm/src/error.rs
 - programs/cp-amm/src/event.rs
 - programs/cp-amm/src/instructions/admin/ix_create_operator_account.rs
 - programs/cp-amm/src/instructions/initialize_pool/ix_initialize_customizable_pool.rs
 - programs/cp-amm/src/instructions/initialize_pool/ix_initialize_pool.rs
 - programs/cp-amm/src/instructions/initialize_pool/ix_initialize_pool_with_dynamic_config.rs
 - programs/cp-amm/src/instructions/ix_update_delegate_permission.rs
 - programs/cp-amm/src/instructions/operator/ix_create_dynamic_config.rs



- programs/cp-amm/src/instructions/operator/ix_create_static_config.rs
- programs/cp-amm/src/state/config.rs
- programs/cp-amm/src/state/operator.rs
- programs/cp-amm/src/state/position.rs
- programs/cp-amm/src/utils/bits.rs
- programs/cp-amm/src/utils/mod.rs
- programs/cp-amm/src/utils/token.rs

Findings

The security audit revealed:

- 0 critical issue
- 0 high issue
- 0 medium issue
- 1 low issues
- 2 informational issues

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.



3 Summary of Findings

ID	Title	Severity	Status
01	Token-2022 Native Mint Check Can Be Skipped	Low	Fixed
02	Mint Bypass Shares the Config Creation Role	Informational	Acknowledged
03	Pool Events Omit Mint Approval Source	Informational	Acknowledged



4 Key Findings and Recommendations

4.1 Token-2022 Native Mint Check Can Be Skipped

Severity: Low

Status: Fixed

Target: Smart Contract

Category: Logic Error

Description

`is_supported_mint` returns `UnsupportNativeMintToken2022` when the supplied mint is the Token-2022 native mint. This rejection cannot be overridden through a `TokenBadge` because the error is returned before badge validation.

```
229     if spl_token_2022::native_mint::check_id(&mint_account.key()) {  
230         return Err(PoolError::UnsupportNativeMintToken2022.into());  
231     }
```

[programs/cp-amm/src/utils/token.rs#L229-L231](#)

However, `initialize_pool` and `initialize_pool_with_dynamic_config` skip the entire mint validation path when the Config has `CreatePoolWithoutMintValidation`. Consequently, the permission bypasses both the optional `TokenBadge` requirement and the explicit `Token-2022 native mint` rejection.

Impact

A private Config with this permission can pass a Token-2022 native mint into pool initialization even though every non-bypass path rejects it.

This weakens the existing mint-admission invariant and exposes the initialization and token-transfer paths to `Token-2022 native mint`, which explicitly designated as unsupported.

Recommendation

It is recommended to preserve the existing invariant that the Token-2022 native mint is unsupported, regardless of the Config permissions granted.

Mitigation Review Log

Fixed in the commit `85bd0b4d049405d8db460fa58d6b7753e1d0785b`.



4.2 Informational and Undetermined Issues

Mint Bypass Shares the Config Creation Role

Severity: Informational

Status: Acknowledged

Target: Smart Contract

Category: Design

`create_config` and `create_dynamic_config` require only the `CreateConfigKey` Operator permission. A holder of this permission can create a private Config with `CreatePoolWithoutMintValidation` and assign any non-default `pool_creator_authority`. That authority can then create static or dynamic Config pools using arbitrary mints without `is_supported_mint` or `TokenBadge` validation.

Because `CreateTokenBadge` is a separate Operator permission, this change effectively gives `CreateConfigKey` holders a Config-scoped ability to delegate arbitrary mint admission without holding `CreateTokenBadge`.

It's recommended to consider introducing a dedicated Operator permission for creating Configs with non-zero permissions, so an operator authorized only to create standard Configs cannot also delegate the ability to bypass mint validation.

Mitigation Review Log

Meteora Team: Add code comments: `CreateConfigKey` can grant `CreatePoolWithoutMintValidation` on a private config. This is similar to `CreateTokenBadge` but on a config level.

Pool Events Omit Mint Approval Source

Severity: Informational

Status: Acknowledged

Target: Smart Contract

Category: Code QA

`initialize_pool` and `initialize_pool_with_dynamic_config` IXs provide two authorization mechanisms for mints that do not satisfy the default mint validation.

- When `CreatePoolWithoutMintValidation` is not granted, an unsupported mint requires a valid `TokenBadge` ;
- When the `permission` is granted, the mint and `TokenBadge` validation is skipped.

However, `EvtInitializePool` does not record which mechanism authorized the mint. Consequently, event indexer cannot determine whether a restricted mint was approved through a `TokenBadge` or the `Config permission`.

It is recommended to record the authorization source for each affected mint, distinguishing `TokenBadge` approval from `Config permission` approval.

Mitigation Review Log

Meteora Team: The approval source can be derived from the tx, remaining accounts for `token_badge` and the config account will contain the bypass perm.



5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

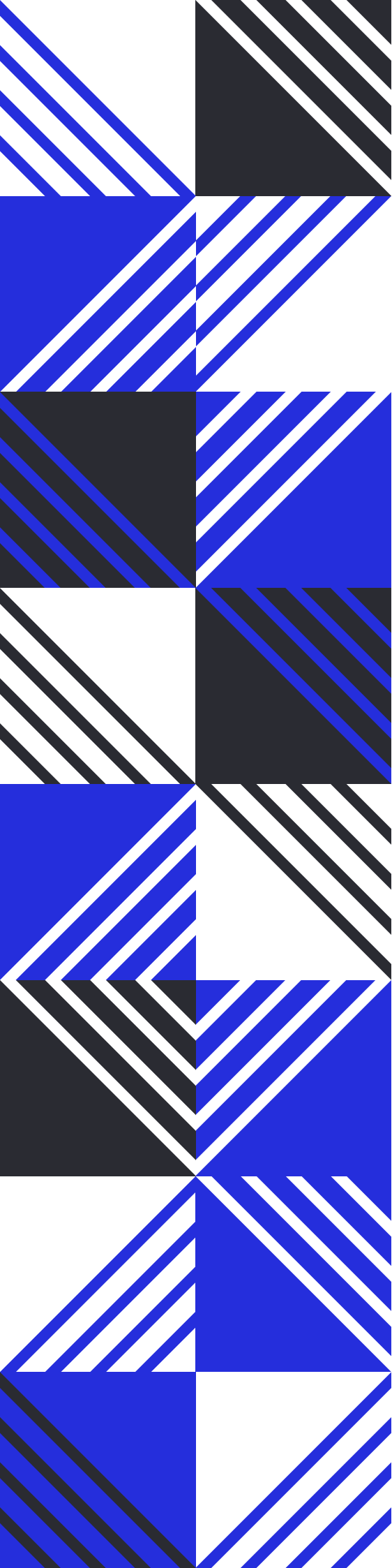
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



 <https://offside.io/>

 <https://github.com/offsidelabs>

 https://twitter.com/offside_labs